

NOVATECH SOLUTIONS - AUDITORÍA DE SEGURIDAD INDEPENDIENTE

- **Rol Simulado:** Junior Risk Analyst / Information Security Evaluator
- **Organización Simulada:** NovaTech Solutions (PyME híbrida de 35 empleados)
- **Marcos y Conceptos Aplicados:** NIST SP 800-30 Rev. 1, Risk Assessment, Threat Identification, Vulnerability Prioritization, Asset Management, CIA Triad, Security Controls.

1. Alcance de la Auditoría (Scope)

El alcance de la evaluación comprende la infraestructura tecnológica y de información de NovaTech Solutions, incluyendo estaciones de trabajo Windows, notebooks corporativas, red Wi-Fi interna y corporativa, servidor de archivos, servicios de almacenamiento en la nube, cuentas de usuario, mecanismos de acceso remoto y procedimientos operativos de TI y Recursos Humanos.

2. Objetivos (Goals)

- Evaluar la postura de seguridad actual de la organización frente a estándares y metodologías de gestión de riesgos (NIST SP 800-30).
- Identificar vulnerabilidades técnicas y debilidades operativas derivadas del crecimiento y la adopción del modelo de trabajo híbrido.
- Analizar y priorizar los riesgos identificados en función de su probabilidad e impacto sobre la Tríada CIA (Confidencialidad, Integridad y Disponibilidad).
- Proveer recomendaciones técnicas accionables y un plan de mitigación para fortalecer el nivel de seguridad de la empresa.

3. Activos Principales (Assets)

- Equipos de cómputo y notebooks corporativas de los empleados.
- Infraestructura de red (Firewall perimetral y red Wi-Fi).
- Servidor de archivos interno y repositorios de almacenamiento en la nube.
- Cuentas de usuario, credenciales de acceso y directorios de autenticación.
- Información de clientes, documentación interna y datos personales de los empleados.

4. Riesgos y Vulnerabilidades Identificados

Durante la revisión inicial de la infraestructura y los procesos de NovaTech Solutions, se identificaron las siguientes vulnerabilidades y debilidades principales:

1. **Cifrado de Dispositivos:** Equipos portátiles (notebooks) corporativos sin cifrado de disco completo.
2. **Control de Accesos:** Permisos de usuario excesivos que incumplen el principio de mínimo privilegio (Least Privilege).
3. **Autenticación:** Uso de contraseñas de al menos 8 caracteres, pero ausencia total de Autenticación Multifactor (MFA).

4. **Acceso Remoto:** Empleados remotos que acceden a recursos corporativos sin utilizar una VPN.
5. **Detección de Amenazas:** Ausencia de un Sistema de Detección de Intrusiones (IDS) para monitorear el tráfico de red.
6. **Respaldo y Recuperación:** Copias de seguridad realizadas manualmente sin calendario definido, sin pruebas formales de restauración y ausencia de un Disaster Recovery Plan (DRP).
7. **Gestión de Activos:** Falta de un inventario actualizado de todos los activos tecnológicos de la empresa.
8. **Factor Humano:** Capacitación básica únicamente al ingresar (onboarding), sin programas de concientización periódicos.
9. **Ciclo de Vida de Accesos (Offboarding):** Procedimiento de baja de accesos operativamente existente pero no formalmente documentado.

5. Controles Existentes (Existing Security Controls)

- Firewall perimetral activo.
- Software antivirus instalado y con actualizaciones periódicas en los equipos.
- Cuentas de usuario individuales para el acceso al servidor.
- Contraseñas con un requisito mínimo de longitud (8 caracteres).
- Seguridad física en oficinas (cerraduras y cámaras de vigilancia).
- Copias de seguridad existentes (aunque de gestión manual).
- Capacitación inicial de seguridad al incorporar nuevos empleados.
- Comunicación operativa entre Recursos Humanos y TI para eliminar accesos ante bajas de personal.

6. Controles Faltantes o que Deberían Mejorarse (Missing / Weak Security Controls)

- Cifrado de disco completo (Full Disk Encryption) en notebooks corporativas.
- Implementación estricta del Principio de Menor Privilegio (PoLP) y control de separación de funciones.
- Autenticación Multifactor (MFA) obligatoria para accesos y cuentas críticas.
- Mecanismos seguros de acceso remoto mediante VPN corporativa.
- Sistema de Detección de Intrusiones (IDS) para la visibilidad y alerta temprana de tráfico anómalo.
- Automatización, calendarización y pruebas periódicas de restauración de respaldos, respaldados por un DRP documentado.
- Inventario de activos centralizado y actualizado (Asset Management).
- Programa periódico de capacitación y concientización en seguridad (Security Awareness Training).
- Procedimiento formal documentado de bajas de personal (Offboarding).

7. Priorización de Riesgos (Risk Assessment & Prioritization)

A continuación se presenta la matriz de evaluación basada en la estimación cualitativa de probabilidad e impacto:

#	Hallazgo	Probabilidad	Impacto	Prioridad
1	Equipos corporativos sin cifrado	Media	Alto	ALTA
2	Permisos excesivos / falta de Least Privilege	Media	Alto	ALTA
3	Ausencia de MFA	Media	Medio	MEDIA
4	Acceso remoto sin VPN	Media	Alto	ALTA
5	Ausencia de IDS	Media	Alto	ALTA
6	Backups deficientes y ausencia de DRP	Media	Alto	ALTA
7	Inventario de activos desactualizado	Media	Alto	ALTA
8	Falta de capacitación periódica	Alta	Medio	ALTA
9	Offboarding no formalizado	Media	Medio	MEDIA

8. Recomendaciones de Seguridad (Security Recommendations)

- Equipos corporativos sin cifrado — Prioridad: ALTA:** La ausencia de cifrado de disco podría permitir el acceso no autorizado a información corporativa en caso de pérdida o robo de un dispositivo, afectando principalmente la confidencialidad de los datos. *Recomendación:* Implementar cifrado de disco completo (FDE) en los equipos corporativos y establecer políticas de gestión de dispositivos móviles y portátiles.
- Permisos excesivos y falta de mínimo privilegio — Prioridad: ALTA:** Algunos empleados tienen acceso a carpetas e información que no necesitan para desempeñar sus funciones, incumpliendo el principio de mínimo privilegio y exponiendo los datos a modificaciones o divulgaciones no autorizadas. *Recomendación:* Revisar los permisos vigentes y reestructurar los accesos basándose estrictamente en las funciones laborales de cada usuario.
- Ausencia de autenticación multifactor (MFA) — Prioridad: MEDIA:** Las cuentas utilizan contraseñas de al menos ocho caracteres, pero no disponen de MFA. Ante un compromiso de credenciales, la falta de una segunda capa facilita el acceso no autorizado. *Recomendación:* Implementar MFA de forma prioritaria en cuentas con privilegios elevados y accesos remotos.
- Acceso remoto sin VPN — Prioridad: ALTA:** El acceso de empleados remotos desde redes externas o no confiables aumenta la exposición de las comunicaciones y recursos corporativos. *Recomendación:* Implementar mecanismos seguros de acceso remoto mediante VPN corporativa y verificar los controles de autenticación y cifrado.
- Ausencia de un Sistema de Detección de Intrusiones (IDS) — Prioridad: ALTA:** La falta de un IDS disminuye la capacidad de la organización para detectar y generar alertas ante patrones de tráfico potencialmente maliciosos, permitiendo que una intrusión

permanezca oculta por más tiempo. *Recomendación:* Implementar capacidades de monitoreo y detección de red mediante un IDS y establecer flujos de análisis de alertas.

6. **Gestión deficiente de backups y ausencia de Disaster Recovery Plan — Prioridad: ALTA:** Las copias de seguridad manuales, sin periodicidad fija ni pruebas de restauración, sumadas a la falta de un DRP, exponen a la empresa a pérdidas irrecuperables de información ante incidentes graves como ransomware. *Recomendación:* Establecer una política formal de respaldos, automatizarlos, supervisar su ejecución, realizar pruebas periódicas de restauración y desarrollar un DRP documentado.
7. **Inventario de activos desactualizado — Prioridad: ALTA:** La falta de un inventario completo impide conocer qué recursos deben ser protegidos, actualizados o monitoreados, ampliando la superficie de ataque de la organización. *Recomendación:* Implementar y mantener actualizado un inventario de activos tecnológicos ("No puedo proteger lo que no sé que tengo").
8. **Falta de capacitación periódica en seguridad — Prioridad: ALTA:** La ausencia de actualización en la formación de los usuarios incrementa el riesgo de éxito ante campañas de phishing, ingeniería social o robo de credenciales. *Recomendación:* Desarrollar un programa periódico de concientización (*Security Awareness Training*).
9. **Proceso de offboarding no formalizado — Prioridad: MEDIA:** Si bien el proceso operativo de baja de accesos existe de manera informal entre RR. HH. y TI, la falta de documentación formal incrementa el riesgo de fallas de comunicación y cuentas activas remanentes de exempleados. *Recomendación:* Documentar formalmente el procedimiento de baja de accesos y responsabilidades asociadas.

9. Conclusión

La auditoría interna permitió identificar los controles de seguridad existentes y las áreas críticas de mejora en NovaTech Solutions. Si bien la organización cuenta con medidas preventivas básicas (antivirus, firewall, contraseñas y controles físicos), presenta vulnerabilidades significativas que impactan la postura general de seguridad. Mediante la priorización analítica de los riesgos, se establecieron recomendaciones orientadas a fortalecer la confidencialidad, integridad y disponibilidad de los activos e información de la empresa.